An official website of the United States government Here's how you know

America's Cyber Defense Agency
NATIONAL COORDINATOR FOR CRITICAL INFRASTRUCTURE SECURITY AND RESILIENCE

Archived Content

In an effort to keep CISA.gov current, the archive contains outdated information that may not reflect current policy or programs.

ICS MEDICAL ADVISORY

Baxter Sigma Spectrum Infusion Pump (Update A)

Last Revised: September 29, 2022 **Alert Code:** ICSMA-22-251-01

1. EXECUTIVE SUMMARY

--------- Begin Update A part 1 of 3 ---------

- **CVSS v3 7.5**

--------- End Update A part 1 of 3 ---------

- **ATTENTION:** Exploitable remotely
- **Vendor:** Baxter
- **Equipment:** Sigma and Baxter Spectrum Infusion Pumps
- **Vulnerabilities:** Missing Encryption of Sensitive Data, Use of Externally Controlled Format String, Missing Authentication for Critical Function

2. UPDATE INFORMATION

This updated advisory is a follow-up to the advisory update titled ICSA-21-251-01 Baxter Sigma Spectrum Infusion Pump that was published September 8, 2022, to the ICS webpage on www.cisa.gov/uscert

3. RISK EVALUATION

Successful exploitation of these vulnerabilities could result in access to sensitive data and alteration of system configuration.

4. TECHNICAL DETAILS

4.1 AFFECTED PRODUCTS

The following versions of Sigma Spectrum Infusion systems are affected:

- Sigma Spectrum v6.x model 35700BAX
- Sigma Spectrum v8.x model 35700BAX2
- Baxter Spectrum IQ (v9.x) model 35700BAX3
- Sigma Spectrum LVP v6.x Wireless Battery Modules v16, v16D38, v17, v17D19, v20D29 to v20D32, and v22D24 to v22D28
- Sigma Spectrum LVP v8.x Wireless Battery Modules v17, v17D19, v20D29 to v20D32, and v22D24 to v22D28
- Baxter Spectrum IQ LVP (v9.x) with Wireless Battery Modules v22D19 to v22D28

4.2 VULNERABILITY OVERVIEW

4.2.1 MISSING ENCRYPTION OF SENSITIVE DATA CWE-311

<https://cwe.mitre.org/data/definitions/311.html>

The Baxter Spectrum WBM (v16, v16D38, v17, v17D19, v20D29 to v20D32, and v22D19 to v22D28) stores network credentials and patient health information (PHI) in unencrypted form. PHI is only stored in Spectrum IQ pumps using auto programming. An attacker with physical access to a device without all data and settings erased may be able to extract sensitive information.

CVE-2022-26390 has been assigned to this vulnerability. A CVSS v3 base score of 4.2 has been calculated; the CVSS vector string is (AV:P/AC:H/PR:N/UI:N/S:U/C:H/I:N/A:N <https://www.first.org/cvss/calculator/3.0#cvss:3.0/av:p/ac:h/pr:n/ui:n/s:u/c:h/i:n/a:n>).

4.2.2 USE OF EXTERNALLY CONTROLLED FORMAT STRING CWE-134 <https://cwe.mitre.org/data/definitions/134.html>

--------- Begin Update A part 2 of 3 ---------

The Baxter Spectrum WBM (v16, v16D38, v17, v17D19, and v20D29 to v20D32) when in superuser mode is susceptible to format string attacks via application messaging. An attacker could use this to read memory in the WBM, potentially accessing sensitive information.

--------- End Update A part 2 of 3 ---------

The Baxter Spectrum WBM (v16, v16D38) and Baxter Spectrum WBM (v17, v17D19, v20D29 to v20D32), when in superuser mode, are susceptible to format string attacks via application messaging. An attacker could use this to read memory in the WBM to access sensitive information.

CVE-2022-26392 has been assigned to this vulnerability. A CVSS v3 base score of 3.1 has been calculated; the CVSS vector string is (AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:N/A:N <https://www.first.org/cvss/calculator/3.0#cvss:3.0/av:n/ac:h/pr:l/ui:n/s:u/c:l/i:n/a:n>).

4.2.3 USE OF EXTERNALLY CONTROLLED FORMAT STRING CWE-134 <https://cwe.mitre.org/data/definitions/134.html>

The Baxter Spectrum WBM (v20D29) is susceptible to format string attacks via application messaging. An attacker could use this to read memory in the WBM to access sensitive information or cause a denial-of-service condition on the WBM.

CVE-2022-26393 has been assigned to this vulnerability. A CVSS v3 base score of 5.0 has been calculated; the CVSS vector string is (AV:N/AC:H/PR:L/UI:N/S:U/C:L/I:L/A:L <https://www.first.org/cvss/calculator/3.0#cvss:3.0/av:n/ac:h/pr:l/ui:n/s:u/c:l/i:l/a:l>).

4.2.4 MISSING AUTHENTICATION FOR CRITICAL FUNCTION CWE-306 <https://cwe.mitre.org/data/definitions/306.html>

--------- Begin Update A part 3 of 3 ---------

The Baxter Spectrum WBM (v16, v16D38, v17, v17D19, and v20D29 to v20D32) does not perform mutual authentication with the gateway server host. This could allow an attacker to perform a machine-in-the-middle attack that modifies parameters, making the network connection fail. Alternatively, an attacker could spoof the server host and send specifically crafted data.

CVE-2022-26394 has been assigned to this vulnerability. A CVSS v3 base score of 7.5 has been calculated; the CVSS vector string is (AV:A/AC:H/PR:N/UI:N/S:C/C:L/I:H/A:L <https://www.first.org/cvss/calculator/3.0#cvss:3.0/av:a/ac:h/pr:n/ui:n/s:c/c:l/i:h/a:l>).

--------- End Update A part 3 of 3 ---------

4.3 BACKGROUND

- **CRITICAL INFRASTRUCTURE SECTORS:** Healthcare and Public Health
- **COUNTRIES/AREAS DEPLOYED:** United States, Canada, Puerto Rico, Caribbean
- **COMPANY HEADQUARTERS LOCATION:** United States

4.4 RESEARCHER

Deral Heiland, Principal IoT Researcher at Rapid 7, reported these vulnerabilities to Baxter.

5. MITIGATIONS

According to Baxter, software updates to disable Telnet and FTP (CVE-2022-26392) are in process. Software updates addressing the format string attack (CVE-2022-26393) are included in WBM version 20D30 and all other WBM versions authentication is already available in Spectrum IQ (CVE-2022-26394).

Instructions to erase all data and settings on WBMs and pumps before decommissioning and transferring to other facilities (CVE-2022-26390) are in process for incorporation into the Spectrum Operator's Manual.

Baxter provides recommended steps for erasing all data and settings on the pump to be decommissioned:

- Reset the network settings (Biomed->Network Configuration->Transfer Network Settings->Reset).
- Delete the drug library.
- Clear the history log.

To erase all data and settings on the WBM to be decommissioned:

- Select a pump other than the one last used with the WBM.
- Reset the network settings and enable networking on the pump.

- Place the WBM on the pump.
- Wait until the network icon turns yellow.

In conjunction with the user's own network security policies, Baxter recommends the following mitigations to reduce the likelihood these vulnerabilities will be exploited:

- Ensure appropriate physical controls within user environments to protect against unauthorized access to devices.
- Isolate the Spectrum Infusion Systems to its own network virtual local area network (VLAN) to segregate the system from other hospital systems and reduce the probability that a threat actor could execute an adjacent attack, such as a machine-in-the-middle attack against the system to observe clear-text communications.
- Use the strongest available wireless network security protocols (WPA2, EAP-TLS, etc.) to provide authentication/encryption of wireless data sent to/from the Spectrum Infusion System.
- Users should ensure the WBM is rebooted after configuration for their network(s) by removing the WBM from the rear of the Spectrum device for 10-15 seconds, and then re-attaching the WBM.
- Users should always monitor for and/or block unexpected traffic, such as FTP and Telnet, at network boundaries into the Spectrum-specific VLAN.

As a last resort, users may disable wireless operation of the pump; the Spectrum Infusion System was designed to operate without network access. This action would impact an organization's ability to rapidly deploy drug library (formulary) updates to their pumps.

For additional information, see the Baxter Product Security Bulletin <https://www.baxter.com/product-security#additionalresources>.

CISA recommends users take defensive measures to minimize the risk of exploitation of this vulnerability these vulnerabilities. Specifically, users should:

- Minimize network exposure for all control system devices and/or systems, and ensure they are not accessible from the Internet <https://www.cisa.gov/uscert/ics/alerts/ics-alert-10-301-01>.

- Locate control system networks and remote devices behind firewalls and isolate them from business networks.
- When remote access is required, use secure methods, such as Virtual Private Networks (VPNs), recognizing VPNs may have vulnerabilities and should be updated to the most current version available. Also recognize VPN is only as secure as its connected devices.

CISA reminds organizations to perform proper impact analysis and risk assessment prior to deploying defensive measures.

CISA also provides a section for control systems security recommended practices <https://us-cert.cisa.gov/ics/recommended-practices> on the ICS webpage at cisa.gov/ics <https://cisa.gov/ics>. Several CISA products detailing cyber defense best practices are available for reading and download, including Improving Industrial Control Systems Cybersecurity with Defense-in-Depth Strategies <https://us-cert.cisa.gov/sites/default/files/recommended_practices/nccic_ics-cert_defense_in_depth_2016_s508c.pdf>.

Additional mitigation guidance and recommended practices are publicly available on the ICS webpage at cisa.gov/ics <https://cisa.gov/ics> in the technical information paper, ICS-TIP-12-146-01B--Targeted Cyber Intrusion Detection and Mitigation Strategies <https://www.cisa.gov/uscert/ics/tips/ics-tip-12-146-01b>.

Organizations observing suspected malicious activity should follow established internal procedures and report findings to CISA for tracking and correlation against other incidents.

No known public exploits specifically target these vulnerabilities. These vulnerabilities have a high attack complexity.

This product is provided subject to this Notification </notification> and this Privacy & Use </privacy-policy> policy.

Vendor

- Baxter

Please share your thoughts

We recently updated our anonymous product survey; we welcome your feedback.

Return to top

Topics </topics> **Spotlight** </spotlight> **Resources & Tools** </resources-tools>

News & Events </news-events> **Careers** </careers> **About** </about>

CISA Central

1-844-Say-CISA contact@cisa.dhs.gov